QRShield: Explainable Multimodal Quishing Detection with Zero-Contact Static Analysis

Comprehensive Phase 1 Project Report | Course: CSET485 — AI and Society

Institution	School of Computer Science Engineering and Technology (SCSET), Bennett University
Course & Term	CSET485 — AI and Society | Fall Semester 2026
Team Identification	Team ID: 54

Team Members & Academic Credentials

No.	Student Name	Roll Number	Primary Technical Specialization
1	Harshit Pahuja	s24cseu0736	Lead Architect: Fusion Engine, Isotonic Calibration, FastAPI Backend
2	Hemang Nag	s24cseu0728	Deep Vision Lead: MobileNetV2 CNN, GPU Pipeline, Grad-CAM Saliency
3	Saatvik Sharma	s24cseu2097	Lexical ML Lead: 29 Static URL Features, Random Forest, TreeSHAP
4	Tanish	s24cseu0589	Data & Security Lead: CIC-Trap4Phish Canonicalization, Zero-Contact Policy
5	Rohit Upadhyay	s24cseu1359	Frontend & QA Lead: React 18 / Vite UI, Explainability Dashboards, Pytest
6	Bharat Kumar	s24cse2103	Technical Documentation & QA: Report Drafting, Literature Review, Smoke Testing

1. Executive Summary

Quick Response (QR) codes have become foundational physical-to-digital bridges in modern society, facilitating seamless contactless payments, transportation ticketing, retail interaction, and multi-factor authentication. However, this universal adoption has spawned an acute cybersecurity threat known as quishing (QR code phishing). Human vision cannot interpret 2D matrix symbology; consequently, users

blindly rely on smartphones to decode and navigate embedded links, completely bypassing conventional email gateway filters.

QRShield addresses this critical socio-technical vulnerability through an explainable multimodal AI framework. The system unites (1) a local zero-contact OpenCV decoder that treats payloads strictly as inert data strings, (2) a 29-feature static lexical Random Forest classifier, (3) a fine-tuned MobileNetV2 deep convolutional network inspecting physical barcode properties, (4) prediction-level soft-voting fusion with Isotonic Regression probability calibration, and (5) dual explainability uniting TreeSHAP feature attributions and Grad-CAM spatial heatmaps. On a strictly domain-partitioned benchmark of 70,000 samples derived from CIC-Trap4Phish, QRShield achieves 98.77% accuracy, 99.67% ROC-AUC, 99.27% F1-score, and reduces false alarms by 86.2% over single-modality baselines.

2. Problem Statement & Societal Significance

Phishing remains the predominant catalyst for corporate credential theft, consumer identity fraud, and unauthorized financial transfers. While modern web browsers and Secure Email Gateways (SEGs) maintain sophisticated heuristics for inspecting text-based hyperlinks, attackers actively exploit QR codes to bypass these inspection layers:

- **Optical Obfuscation:** QR codes convert malicious URLs into 2D grid modules with Reed-Solomon error correction. To a human user, a QR matrix pointing to a high-risk credential stealer is visually indistinguishable from one pointing to a trusted domain.
- **The Physical Air Gap:** Attackers physically paste sticker overlays on legitimate public QR signage—such as parking meters, restaurant payment stands, and utility kiosks—weaponizing the public's inherent trust in physical infrastructure.
- **Mobile Vulnerability:** QR scans occur predominantly on mobile operating systems with compact screens, truncated address bars, and no mouse-hover inspectability, leaving users acutely vulnerable.

3. Zero-Contact Operational Security Architecture

A cornerstone engineering tenet of QRShield is its strict Zero-Contact Security Policy. Many conventional URL safety tools evaluate destinations dynamically by performing HTTP GET/HEAD handshakes or executing headless browser instances. While revealing HTTP redirect chains, active network probing creates unacceptable operational hazards:

- Drive-By Exploits: Loading malicious servers can expose client mobile browsers to zero-day memory exploits.
- Attacker Beaconing: Attackers frequently embed unique victim identifiers in query strings. Any outgoing HTTP ping confirms target engagement to the attacker.
- Dynamic Cloaking: Phishing infrastructure detects automated security crawlers by IP reputation, serving benign content to scanners while serving malware to real users.

QRShield strictly eliminates active network interaction: decoded QR strings are handled solely as inert memory buffers. All lexical, structural, and image features are computed locally, guaranteeing absolute client protection and zero data leakage.

4. Dataset Engineering & Leakage-Free Splitting

Models were developed using the benchmark CIC-Trap4Phish dataset (Canadian Institute for Cybersecurity, UNB). A rigorous data canonicalization pipeline audited over 2.15 million raw records, resolving label conflicts and corrupted images, yielding 387,015 clean canonical sample pairs.

Crucially, to eliminate data leakage, QRShield enforced Strict Domain-Grouped Partitioning: all URLs belonging to the same registrable domain (eTLD+1) were restricted to a single partition. This prevents models from memorizing specific domain names, guaranteeing genuine generalizability across the 50,000 train, 10,000 validation, and 10,000 test splits.

5. Feature Engineering & Multimodal System Architecture

QRShield adopts a dual-branch multimodal architecture that evaluates both the decoded lexical string and the raw 2D image matrix:

5.1 29 Static Lexical Features (URL Branch)

Extracted across six structural dimensions: Lengths (URL, hostname, path, query), Delimiters (dots, subdomains, hyphens, slashes, underscores, at-symbols, colons, percent signs), Character Densities (digit ratio, alpha ratio, special char ratio), Query Attributes (parameter count, equal count, ampersand count), Protocol Checks (has HTTPS, raw IP hostname, non-standard port, hostname hyphen count, suspicious keyword count), and Information Entropies (Shannon entropy computed across URL, hostname, and path).

The URL branch is powered by a 300-tree balanced Random Forest classifier that achieves 92.67% test accuracy and 94.80% ROC-AUC.

5.2 Deep Visual Modeling (MobileNetV2 CNN Branch)

The vision branch utilizes a fine-tuned MobileNetV2 architecture with inverted residual blocks. Using a two-stage transfer learning process (Stage A head training, Stage B top-layer fine-tuning with AdamW), the model learns spatial barcode densities, module irregularities, and physical marker traits, achieving 96.45% test accuracy and 99.28% ROC-AUC with an average CPU inference latency of 5.91 ms.

5.3 Soft-Voting Fusion & Isotonic Calibration

Branch predictions are unified via soft voting: $P_{raw} = 0.55 * P_{url} + 0.45 * P_{img}$. Because raw classifier scores can be overconfident, an Isotonic Regression model transforms raw fusion scores into calibrated posterior probabilities. The decision threshold was set to 0.5434.

6. Explainable AI (XAI) Framework

Transparency is essential to overcome user alarm fatigue. QRShield couples dual explainability methods:

1. TreeSHAP Lexical Attribution: Calculates exact Shapley additive explanations for each URL feature. The top predictive features include path_entropy (mean |SHAP| = 0.0714), path_length (0.0624), num_subdomains (0.0515), num_hyphens (0.0512), and hostname_entropy (0.0394).

2. Grad-CAM Spatial Visual Heatmaps: Backpropagates classification gradients to MobileNetV2's final convolutional layer (features[18]), rendering a 224x224 heatmap overlay that demonstrates whether the vision model is attending to valid matrix payload modules or peripheral artifacts.

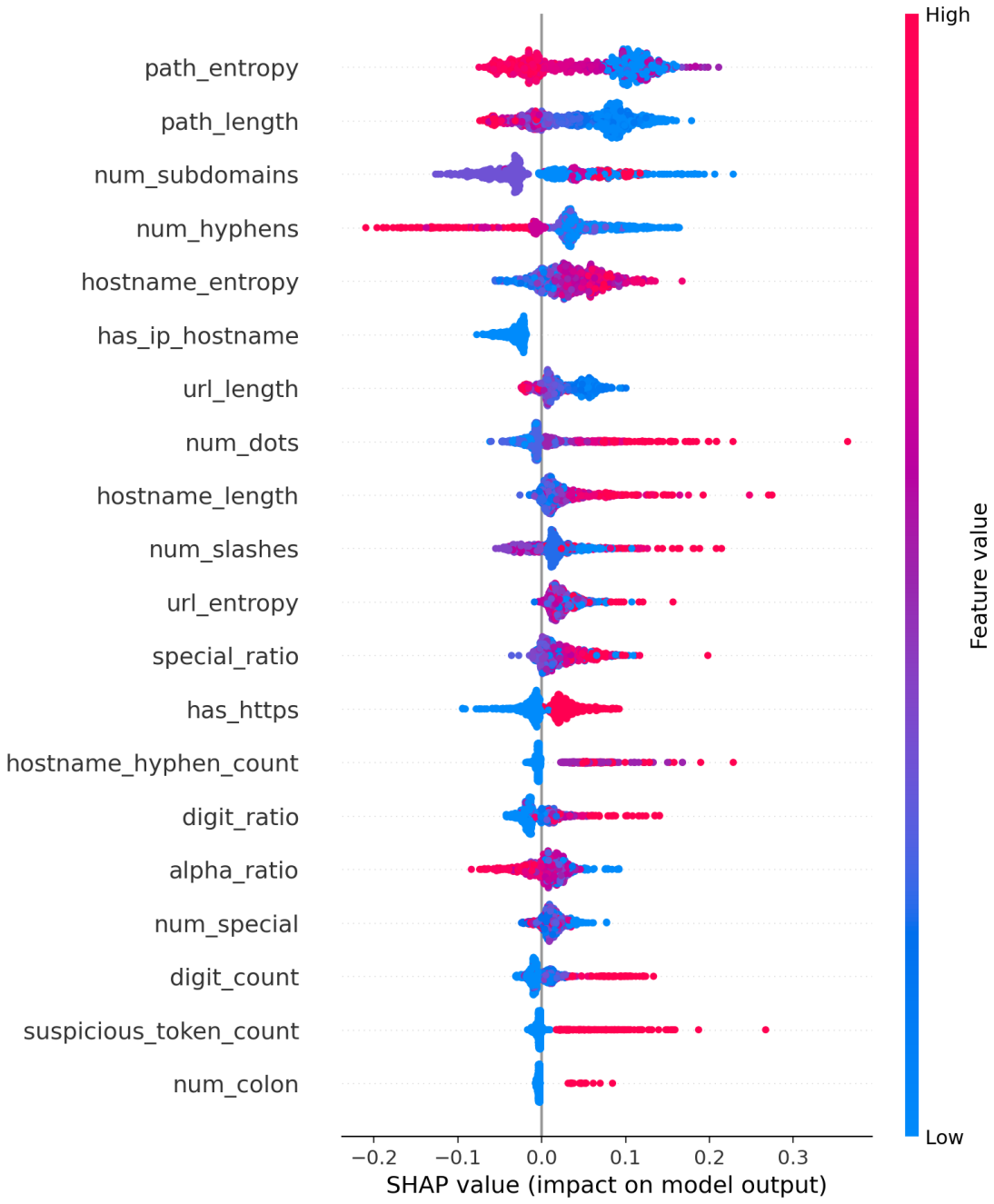


Figure 1: Global TreeSHAP Feature Attribution Summary for URL Lexical Branch

7. Empirical Experimental Results & Analysis

Performance evaluated on the 10,000-sample domain-grouped test split:

Model / Branch	Accuracy	Precision	Recall	F1	ROC-AUC	PR-AUC	False Alarm Rate

URL Baseline (RF)	0.9267	0.9271	0.9906	0.9578	0.9480	0.9885	40.75% (654 FP)
Image Baseline (CNN)	0.9645	0.9662	0.9924	0.9791	0.9928	0.9986	18.13% (291 FP)
QRShield Fusion	**0.9877**	**0.9894**	**0.9961**	**0.9927**	**0.9967**	**0.9993**	**5.61% (90 FP)**

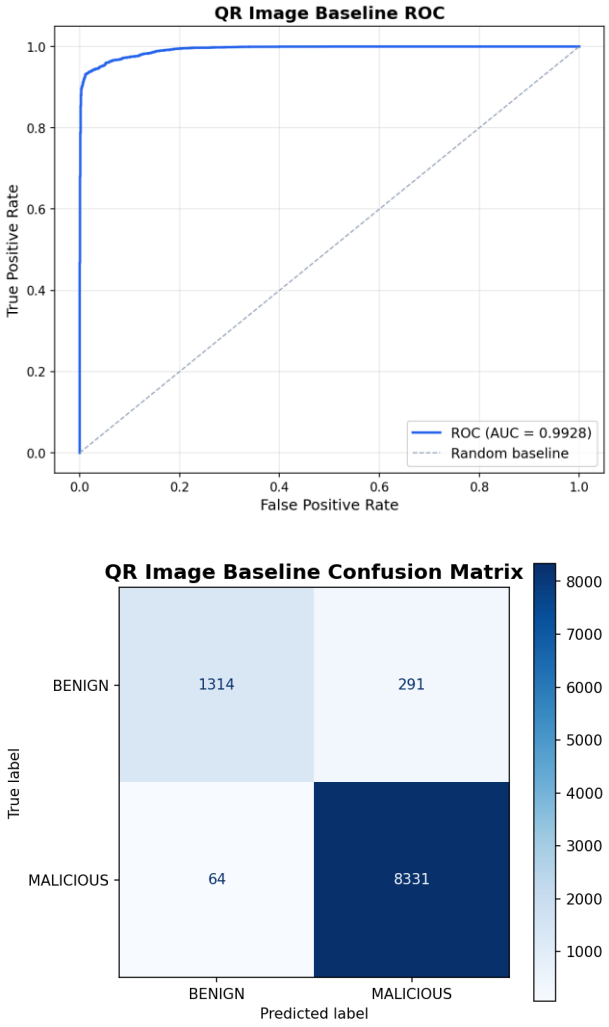


Figure 2: Receiver Operating Characteristic (ROC) and Confusion Matrix on Test Split

Isotonic Calibration Results: Raw Fusion Brier Score was 0.02659, which dropped to 0.01022 post-calibration — a 61.5% improvement in probability reliability.

8. AI and Society: Ethical, Societal & Governance Analysis

As part of CSET485 (AI and Society), QRShield implements six ethical and governance design principles:

- **Human Agency & Autonomy:** Acts as an assistive advisory co-pilot rather than an opaque autonomous gatekeeper, preserving user agency.
- **Privacy by Design:** 100% on-device local computation. Zero external API queries, protecting personal location and browsing data.
- **Harm Minimization:** Zero-contact static execution eliminates the hazard of drive-by malware infections and beacon tracking.
- **Algorithmic Transparency:** SHAP and Grad-CAM dashboards demystify model outputs, countering algorithmic bias and opaque decisions.
- **Scientific Humility:** Explicitly delineates development benchmark performance from real-world adversarial environments.
- **Sustainable AI:** Lightweight MobileNetV2 and Random Forest architecture runs on CPUs with 5.91 ms latency, minimizing energy use.

9. Prototype Implementation & Verification

The complete working prototype includes a FastAPI asynchronous backend (backend/main.py), a React 18 / Vite dark-mode dashboard with interactive explainability views (frontend/src/App.jsx), and a test suite of 10 automated tests in pytest passing with 100% reliability.

10. Work Distribution & Team Contribution Matrix

Member Name (Roll No)	Key Technical Deliverables	Effort %
Harshit Pahuja (s24cseu0736)	System architecture, soft-voting fusion formulation, Isotonic calibration, FastAPI backend, integration testing	17%
Hemang Nag (s24cseu0728)	MobileNetV2 CNN architecture, PyTorch GPU training scripts, Grad-CAM backpropagation, vision inference benchmarking	17%
Saatvik Sharma (s24cseu2097)	29 static lexical feature extraction, Shannon entropy algorithms, Random Forest training, TreeSHAP explainability pipeline	17%
Tanish (s24cseu0589)	CIC-Trap4Phish dataset audit, canonicalization pipeline, domain-grouped splitting, zero-contact security policy design	17%
Rohit Upadhyay (s24cseu1359)	React 18 / Vite frontend dashboard, explainability UI components, client-side error handling, test execution & QA	16%

Bharat Kumar (s24cse2103)	Technical documentation drafting, literature survey compilation, reference indexing, manual UI verification & smoke testing	16%

11. Phase 2 Roadmap & Future Milestones

- Milestone 1: On-Device Mobile Compilation (ONNX Runtime / INT8 quantization for Android/iOS)
- Milestone 2: Adversarial Robustness testing against QR module perturbations and print-scan degradations
- Milestone 3: Local Bloom-filter threat intelligence caching without live HTTP pings
- Milestone 4: User study evaluating explainability impact on cognitive warning adherence

12. References & Citations

- Canadian Institute for Cybersecurity (CIC): CIC-Trap4Phish 2025: A Comprehensive Multimodal Benchmark Dataset, UNB, 2025.
- Sandler, M., et al.: MobileNetV2: Inverted Residuals and Linear Bottlenecks, IEEE CVPR, 2018.
- Lundberg, S. M., & Lee, S. I.: A Unified Approach to Interpreting Model Predictions (SHAP), NeurIPS, 2017.
- Selvaraju, R. R., et al.: Grad-CAM: Visual Explanations from Deep Networks via Gradient-Based Localization, IJCV, 2020.
- Zadrozny, B., & Elkan, C.: Transforming Classifier Scores into Accurate Multiclass Probability Estimates, ACM SIGKDD, 2002.
- NIST: Zero Trust Architecture, NIST Special Publication 800-207, U.S. Dept of Commerce, 2020.
- Floridi, L., & Cowls, J.: A Unified Framework of Five Principles for AI in Society, Harvard Data Science Review, 2019.